Tà Xùa Trip – Kế hoạch build hệ thống toàn diện

Bản hợp nhất để build Tà Xùa Trip thành nền tảng cộng đồng du lịch: chat chia theo loại không gian, mọi nội dung và hội thoại nằm trong một nền tảng dữ liệu có phân quyền, và AI truy xuất dữ liệu đó mà không vượt quá quyền của người hỏi. Lộ trình ở mục 7 thay cho lộ trình sprint ở tab đầu, vì đã thêm chat cộng đồng và nền tảng dữ liệu.

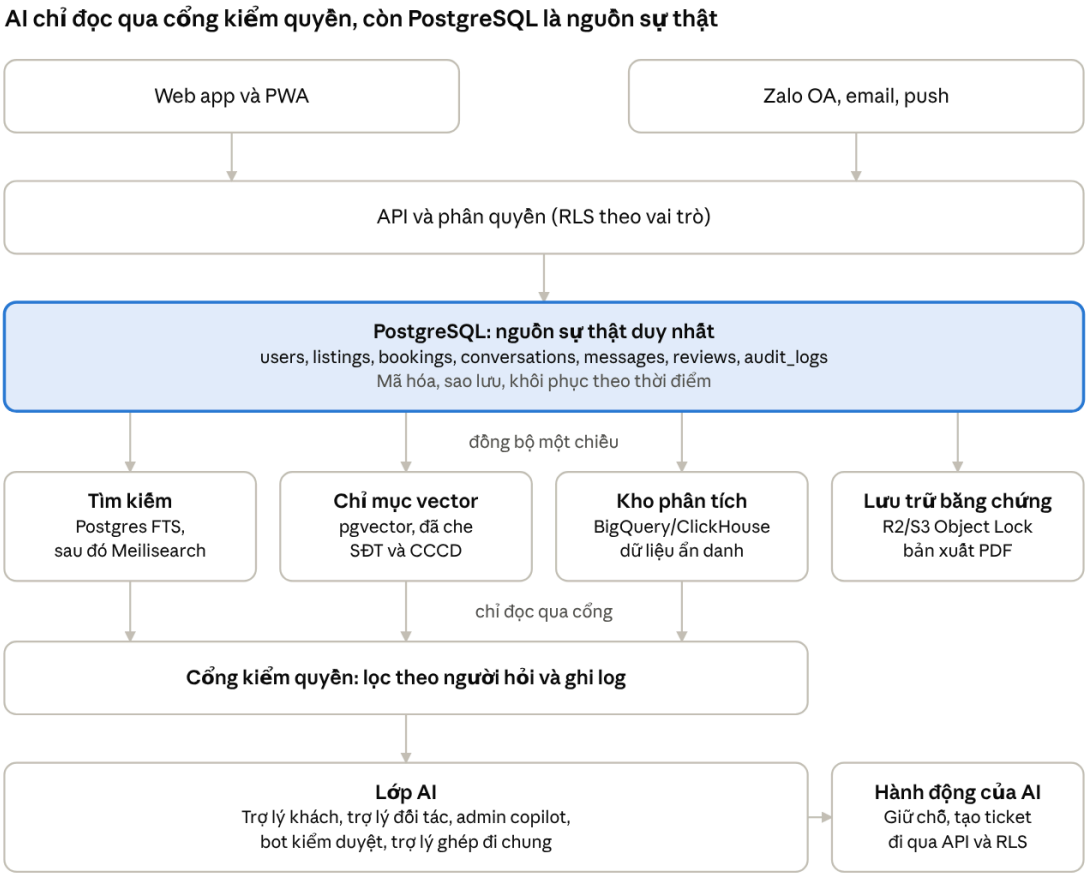
1. Phạm vi hệ thống: 10 module

Tính năng chi tiết cho chủ cơ sở, member và nhà xe nằm ở mục 5 đến 8 của tab đầu; tab này tập trung vào chat, dữ liệu và AI.

#	Module	Vai trò	Dữ liệu chính
1	Danh tính và phân quyền	Đăng ký, vai trò, xác minh	users, roles, verifications
2	Danh bạ dịch vụ	Hồ sơ homestay, xe, tour, quán có phiên bản	listings, listing_versions, media
3	Lịch trống và giá	Nguồn dữ liệu cho booking và AI	availability, pricing_rules
4	Booking và thanh toán	Giữ chỗ, QR check-in, ví đối tác, phí 50.000đ	bookings, payments, wallet_ledger
5	Cộng đồng và chat	Kênh, nhóm, ghép đi chung, chat 1-1, khiếu nại	conversations, messages
6	Review và uy tín	Review xác thực, điểm tin cậy	reviews, trust_scores
7	Nội dung	Blog, hỏi đáp, bảng tin mây, nhật ký chuyến đi	posts, comments, weather_reports
8	Lớp AI	Trợ lý khách, trợ lý đối tác, trợ lý admin, kiểm duyệt	ai_runs, embeddings
9	Quản trị và CSKH	Duyệt hồ sơ, khiếu nại, tài chính, nhật ký kiểm toán	tickets, disputes, audit_logs
10	Nền tảng dữ liệu	Kho phân tích, chỉ mục vector, lưu trữ bằng chứng	warehouse, vectors, archive

2. Kiến trúc tổng thể

PostgreSQL là nguồn sự thật duy nhất; tìm kiếm, vector, kho phân tích và lưu trữ lạnh đều đồng bộ từ đó, nên dữ liệu nhất quán và AI không đọc từ nguồn nào không có phân quyền.



kiến trúc dữ liệu và AI · 5 tầng

Đọc từ trên xuống: ứng dụng gọi API có phân quyền, mọi dữ liệu nằm trong PostgreSQL và đồng bộ một chiều sang bốn nơi. AI chỉ đọc qua cổng kiểm quyền, và các hành động của AI vẫn đi qua API như người dùng thường.

3. Hệ thống chat cộng đồng

3.1 Các loại không gian chat

Mỗi loại có người tham gia, vòng đời và mức lưu trữ riêng, để một nhóm trò chuyện vui không bị xử lý như một cuộc đàm phán tiền.

Loại	Mục đích	Thành viên	Tạo và vòng đời	Mức lưu trữ
Thông báo chung	Tin chính thức của nền tảng	Mọi member; chỉ admin đăng	Cố định	Xã hội
Cộng đồng chung và kênh chủ đề	Hỏi đáp mở	Member đã xác minh	Admin tạo, moderator quản lý	Xã hội

Loại	Mục đích	Thành viên	Tạo và vòng đời	Mức lưu trữ
(#hỏi-đáp, #mây-hôm-nay, #đường-đi, #ăn-uống)				
Nhóm đối tác theo loại dịch vụ	Hỗ trợ và chia sẻ giữa nhà cung cấp	Nhà cung cấp đã duyệt cùng loại	Admin tạo	Xã hội
Phòng chuyến	Thông tin cho cả đoàn trong cùng cuối tuần	Khách có booking xác nhận trong cùng khoảng ngày	Tự tạo theo ngày đến, tự đóng sau chuyến	Xã hội
Kèo ghép đi chung (ghép xe, phòng, tour, chụp ảnh)	Tìm bạn đi chung	Người đăng kèo và người được duyệt	Tạo từ bài đăng kèo; phòng chat mở khi có người được duyệt; đóng sau chuyến	Xã hội, có nhật ký báo cáo
Chat 1-1 gắn listing hoặc booking	Khách hỏi và đặt với nhà cung cấp	Khách, nhà cung cấp (AI trả lời hộ nếu chủ bật)	Tạo khi khách hỏi, gắn vào booking	Bằng chứng
Phòng booking nhiều bên	Phối hợp xe đưa đón, homestay, quán trong một booking	Khách và các nhà cung cấp của booking	Tự tạo khi booking có từ 2 nhà cung cấp	Bằng chứng
Hỗ trợ (ticket)	Khách hoặc đối tác nhờ hỗ trợ	Người hỏi, AI, CSKH	Tạo khi bấm Hỗ trợ	Bằng chứng
Phòng khiếu nại	Giải quyết tranh chấp	Khách, nhà cung cấp, admin trung gian	Admin mở, đóng băng các chat liên quan	Bằng chứng, giữ lâu hơn
SOS và cứu hộ	Khẩn cấp	Người gặp sự cố, đội cứu hộ đã xác minh, admin	Mở bằng nút SOS kèm vị trí	Bằng chứng

3.2 Hai mức lưu trữ

Mức	Áp dụng	Quy tắc
Bằng chứng	Chat 1-1, phòng booking, ticket, khiếu nại, SOS	Chỉ ghi thêm; timestamp từ server; hash nối chuỗi; không xóa thật (chỉ ẩn); xuất PDF có mã xác thực;

Mức	Áp dụng	Quy tắc
		giữ tối thiểu 3 năm (đề xuất, cần luật sư xác nhận); mọi lần admin xem đều có log
Xã hội	Thông báo, kênh chủ đề, nhóm đối tác, phòng chuyến, kèo	Thành viên sửa hoặc xóa tin của mình trong 15 phút, bản gốc vẫn lưu ẩn để moderator xem khi có báo cáo; giữ 12 tháng (đề xuất) rồi chuyển lưu trữ lạnh và ẩn danh

3.3 Ghép người đi chung: luồng chi tiết

1. Thành viên đăng "kèo": loại (xe, phòng, tour, chụp ảnh), ngày, điểm đi và đến, số chỗ còn, cách chia chi phí, yêu cầu về nhóm, mô tả.
2. Người khác bấm "Xin ghép"; người đăng xem hồ sơ tin cậy (đã xác minh SĐT, số chuyến, review xác thực, huy hiệu) rồi duyệt.
3. Khi có người được duyệt, hệ thống mở phòng chat của kèo. Thông tin liên hệ cá nhân chỉ hiện sau khi hai bên chấp nhận.
4. Đủ người thì chốt kèo, có thể gắn với booking homestay hoặc xe trên nền tảng ("đặt chung").
5. Sau chuyến, mời đánh giá bạn đồng hành để cộng vào điểm tin cậy; nội dung đánh giá không công khai.

Nguyên tắc an toàn cho tính năng này:

- Chỉ member đã xác minh SĐT mới được đăng kèo hoặc xin ghép; có nút báo cáo và chia sẻ vị trí hành trình trong phòng kèo.
- Nền tảng không thu hộ hay chia tiền giữa các thành viên ở giai đoạn đầu; điều khoản nêu rõ nền tảng chỉ là nơi kết nối.
- Ghép xe có thu tiền của người lạ có thể bị coi là kinh doanh vận tải. Chỉ cho phép chia chi phí thực tế, cấm thu lợi, và hỏi luật sư trước khi mở tính năng ghép xe.
- AI gắn cờ kèo có dấu hiệu thu tiền cọc hoặc rủ chuyển khoản ngoài.

3.4 Phân quyền trong chat

Hành động	Thành viên	Moderator	Chủ phòng (người đăng kèo)	Admin	AI
Gửi tin	Có, trừ phòng chỉ đọc	Có	Có	Có	Theo kịch bản
Sửa hoặc xóa tin của mình	15 phút (mức xã hội)	Có	Có	Có	Không
Ghim tin	Không	Có	Có	Có	Không

Hành động	Thành viên	Moderator	Chủ phòng (người đăng kèo)	Admin	AI
Ẩn tin vi phạm	Báo cáo	Có	Trong phòng của mình	Có	Chỉ gắn cờ
Mời hoặc loại thành viên	Không	Có	Có	Có	Không
Đọc phòng mức bằng chứng	Chỉ phòng của mình	Không	Không	Chỉ khi có ticket, có log	Chỉ phần được cấp để tóm tắt
Xuất hội thoại	Của chính mình	Không	Không	Có, cần hai người duyệt	Không

3.5 Tính năng của chat

- Thời gian thực; ảnh và video nén; vị trí; tin nhắn thoại.
- Thẻ báo giá và thẻ booking: giá chốt trong chat có giá trị ràng buộc và khớp với booking.
- Khảo sát nhanh, trả lời theo luồng, nhắc tên (@), ghim tin.
- Dịch tự động Việt, Anh, Hàn, Trung cho khách nước ngoài.
- Thông báo tùy chỉnh: tắt tiếng, bản tóm tắt cuối ngày thay vì từng tin.
- Đọc và gửi lại tin khi mất mạng (PWA), vì nhiều khu vực ở Tà Xùa sóng yếu.
- Báo cáo tin nhắn; giới hạn tốc độ chống spam; hiển thị huy hiệu vai trò và mức xác minh bên cạnh tên.

3.6 Kiểm duyệt nhiều lớp

1. AI lọc tức thì: spam, lừa đảo, rủ chuyển khoản ngoài, thông tin cá nhân, ngôn từ thù ghét.
2. Thành viên báo cáo.
3. Hàng chờ moderator, cam kết xử lý trong 1 giờ giờ hành chính.
4. Admin xử lý ca khó và kháng cáo.

Mức xử lý: nhắc nhở, tạm khóa đăng, loại khỏi nhóm, khóa tài khoản. Mọi quyết định ghi lý do và có đường kháng cáo.

3.7 Nối với Zalo và Facebook

Giai đoạn đầu chỉ nối một chiều: Zalo OA gửi thông báo “có tin nhắn mới” kèm liên kết mở website; Page và Group chia sẻ bài. Không đồng bộ hai chiều nội dung chat sang nền tảng ngoài, vì sẽ mất kiểm soát dữ liệu và phụ thuộc chính sách của họ.

4. Quản trị dữ liệu và truy xuất bằng AI

4.1 Phân loại dữ liệu

Loại	Ví dụ	Lưu ở	Thời gian lưu (đề xuất)	AI được dùng
Công khai	Hồ sơ đã duyệt, blog, hỏi đáp công khai, review hiển thị	Postgres, chỉ mục tìm kiếm, vector	Không giới hạn	Có, cho mọi người dùng
Nội bộ	Thống kê, lịch sử giá, nhật ký hệ thống	Kho phân tích	3 đến 5 năm	Có, cho admin, ẩn danh khi có thể
Nhạy cảm	Chat, booking, SĐT, vị trí, ticket	Postgres mã hóa, lưu trữ lạnh	Chat bằng chứng 3 năm, chat xã hội 12 tháng	Có, theo quyền người hỏi, đã che thông tin cá nhân trước khi lập chỉ mục
Rất nhạy cảm	CCCD, giấy phép kinh doanh, mã giao dịch thanh toán	Bucket riêng, mã hóa từng trường, KMS	Theo luật, xóa khi hết nghĩa vụ	Không bao giờ đưa vào AI

4.2 Mô hình dữ liệu chat

Bảng	Cột chính	Ghi chú
conversations	id, type, tier (social hoặc evidence), subject (listing, booking, trip, post), status, created_by, closed_at, retention_until	type theo mục 3.1
conversation_members	conversation_id, user_id, role, joined_at, left_at, muted	Quyền được kiểm tra ở mỗi truy vấn
messages	id, conversation_id, seq, sender_id, kind, body, meta (JSON), reply_to, lang, created_at (server), prev_hash, hash	Chỉ INSERT; seq tăng đều theo phòng để phát hiện thiếu tin
message_versions	message_id, version, body, created_at, reason	Sửa tin là thêm phiên bản, không ghi đè
message_attachments	message_id, storage_key, mime, size, sha256, scan_status	Lưu hash tệp để chứng minh không bị đổi
message_moderation	message_id, source (ai, user, mod), label, score, decision, decided_by	Dùng khi kháng cáo

Bảng	Cột chính	Ghi chú
conversation_exports	id, conversation_id, requested_by, approved_by, pdf_key, verify_code, created_at	Cần hai người duyệt
access_logs	id, actor_id, object, action, reason, ticket_id, created_at	Chỉ ghi thêm
legal_holds	conversation_id, reason, set_by, set_at, released_at	Chặn xóa tự động khi có khiếu nại

4.3 Kiến trúc dữ liệu theo tầng

Tầng	Công cụ gợi ý	Vai trò
1. Nguồn sự thật	PostgreSQL (Supabase)	Mọi ghi nhận, RLS, sao lưu và khôi phục theo thời điểm
2. Đồng bộ	Job theo lô hoặc bắt thay đổi từ Postgres, hàng đợi	Đẩy sang các tầng dưới, có kiểm tra khớp số lượng
3. Kho phân tích	BigQuery hoặc ClickHouse, mô hình hóa bằng dbt	Báo cáo, dashboard, hỏi bằng ngôn ngữ tự nhiên; dữ liệu đã ẩn danh
4. Chỉ mục AI	pgvector (bắt đầu), Qdrant khi quy mô lớn	Tìm theo ngữ nghĩa trên nội dung công khai và chat đã che thông tin cá nhân
5. Lưu trữ bằng chứng	R2 hoặc S3 có khóa không cho sửa (Object Lock)	Bản xuất PDF và ảnh chụp dữ liệu của vụ khiếu nại

Giai đoạn đầu chỉ cần tầng 1, tầng 4 (pgvector ngay trong Postgres) và bản xuất PDF. Tách kho phân tích khi dữ liệu đủ lớn để làm chậm hệ thống chính.

4.4 AI truy xuất dữ liệu: ai được hỏi gì

Tình huống	Nguồn dữ liệu	Quyền	Cách làm
Khách hỏi chatbot	Hồ sơ công khai, lịch, giá, hỏi đáp	Dữ liệu công khai và booking của chính khách	Tìm theo ngữ nghĩa, lịch và giá lấy bằng truy vấn SQL; không có chat của người khác
Chủ cơ sở hỏi trợ lý	Booking, chat, review, thống kê của cơ sở mình	Chỉ cơ sở của họ	Lọc theo provider_id ở tầng dữ liệu
Admin hỏi “vụ tranh chấp này diễn ra thế nào”	Chat mức bằng chứng của ticket đó	Admin có ticket và để lại log	Tóm tắt chuỗi tin trong phạm vi ticket, kèm trích dẫn tin gốc

Tình huống	Nguồn dữ liệu	Quyền	Cách làm
Admin hỏi “nhà xe nào bị phàn nàn nhiều”	Kho phân tích	Admin, dữ liệu ẩn danh	Hỏi bằng ngôn ngữ tự nhiên, chạy SQL chỉ đọc trên các view đã duyệt
Bot kiểm duyệt	Tin nhắn mới	Chỉ nội dung tin	Phân loại và gắn cờ
Phân tích câu hỏi hay gặp	Kênh #hỏi-đáp	Đã ẩn danh	Gom nhóm câu hỏi, đề xuất bài blog và mục FAQ

Quy tắc bắt buộc:

- Quyền được kiểm tra ở tầng dữ liệu (RLS và bộ lọc truy vấn) cho từng truy vấn, không dựa vào lời dặn trong prompt.
- Che thông tin cá nhân (SĐT, CCCD, số tài khoản, địa chỉ nhà) trước khi tạo embedding.
- Mỗi lần AI đọc dữ liệu nhạy cảm đều ghi vào access_logs kèm lý do.
- Nội dung chat là dữ liệu, không phải lệnh: AI không làm theo chỉ dẫn nằm trong tin nhắn (chống prompt injection). Các công cụ như hoàn tiền hay đổi giá không giao cho AI.
- Chia chat thành các đoạn theo cửa sổ hội thoại (ví dụ 20 tin) kèm conversation_id, thời gian, vai trò để trích dẫn nguồn.
- Mọi câu trả lời của AI trích dẫn tin hoặc hồ sơ gốc để admin kiểm chứng.

4.5 Quyền riêng tư và pháp lý về dữ liệu

Các điểm dưới đây cần luật sư xác nhận trước khi ra mắt.

- Xin đồng ý riêng và tách bạch cho ba việc: (1) lưu chat để giải quyết tranh chấp, (2) dùng nội dung để phân tích và cải thiện dịch vụ, (3) dùng để huấn luyện hoặc tinh chỉnh AI (mặc định tắt).
- Chat không mã hóa đầu cuối vì cần lưu bằng chứng; nói rõ điều này với người dùng ngay khi đăng ký.
- Quyền xóa và quyền truy cập của chủ thể dữ liệu có thể va chạm với nghĩa vụ giữ bằng chứng. Dùng cơ chế “khóa pháp lý” (legal_holds) và giải thích trong chính sách.
- Khi gửi dữ liệu cho dịch vụ AI bên ngoài, chỉ gửi phần cần thiết và đã che thông tin cá nhân; đọc kỹ điều khoản xử lý dữ liệu của nhà cung cấp. Việc chuyển dữ liệu cá nhân ra nước ngoài có thể kèm thủ tục theo Nghị định 13/2023 và quy định mới hơn.
- Có người phụ trách bảo vệ dữ liệu và hồ sơ đánh giá tác động xử lý dữ liệu cá nhân.

4.6 Quy trình admin xem chat riêng

1. Chỉ mở chat mức bằng chứng khi có ticket hoặc khiếu nại.
2. Admin nhập lý do; hệ thống ghi log trước khi hiển thị.
3. Xuất hội thoại cần hai người duyệt.
4. Điều khoản nêu rõ cho người dùng khi nào admin có thể xem tin của họ.
5. Rà soát nhật ký truy cập hằng quý; bất thường chuyển cho Community Lead.

4.7 Bảo mật và chất lượng dữ liệu

- TLS mọi nơi, mã hóa lưu trữ, mã hóa từng trường cho thông tin cá nhân với khóa quản lý riêng (KMS).
- Kiểm thử thâm nhập trước ra mắt; sao lưu hằng ngày và thử khôi phục hằng quý.
- Hợp đồng dữ liệu (schema) giữa các tầng, có cảnh báo khi dữ liệu lệch.
- Điểm đầy đủ hồ sơ, phát hiện ảnh trùng, giám sát đồng bộ lịch (lịch cũ quá 7 ngày bị gắn nhãn).

5. Lớp AI chi tiết

Trợ lý	Người dùng	Công cụ được gọi	Giới hạn bắt buộc
Concierge khách	Khách, member	search_listings, check_availability, quote_price, create_hold, get_cloud_forecast, get_route, create_ticket	Giá và lịch chỉ lấy từ DB; không tự xác nhận booking khi chủ chưa bật; chuyển người khi có tranh chấp tiền hoặc vấn đề an toàn
Trợ lý đối tác	Chủ cơ sở, nhà xe	update_availability, suggest_price, draft_reply, translate, get_stats	Chỉ dữ liệu của chính họ; giá đề xuất do chủ duyệt
Admin copilot	CSKH, admin	summarize_thread, find_similar_cases, draft_resolution, query_warehouse (chỉ đọc)	Có ticket và log; quyết định về tiền do người
Bot kiểm duyệt	Hệ thống	classify_message, flag	Chỉ gắn cờ; hình phạt do moderator quyết
Trợ lý ghép đi chung	Member	match_trips, check_profile_trust	Không lộ thông tin cá nhân khi chưa chấp nhận
Trợ lý nội dung và SEO	Đội nội dung	cluster_questions, draft_post	Bài đăng cần người duyệt

Cách vận hành để giữ chất lượng:

- Bộ 200 câu hỏi chuẩn (golden set) để chấm trước mỗi lần cập nhật; mục tiêu sai giá hoặc sai lịch là 0.
- Đo tỷ lệ giải quyết không cần người, thời gian phản hồi, tỷ lệ chuyển người đúng lúc.
- Thử trên môi trường dữ liệu giả; log đầy đủ mọi lần gọi; có công tắc tắt khẩn cấp cho từng trợ lý.
- Theo dõi chi phí theo trợ lý để điều chỉnh mô hình dùng cho từng việc.

6. Quản lý toàn bộ nội dung trên website

Mọi loại nội dung dùng chung một khung: có người tạo, trạng thái duyệt, thẻ phân loại và gắn với một đối tượng (cơ sở, tuyến, chuyến, booking). Nhờ vậy AI và tìm kiếm truy xuất được bằng cùng một cách.

Loại nội dung	Ai tạo	Kiểm duyệt	Vòng đời	Truy xuất bằng AI
Hồ sơ cơ sở, thực đơn, tuyến xe	Nhà cung cấp	Admin duyệt trước khi hiện	Có phiên bản, giữ mãi	Có, nguồn chính cho chatbot
Blog và cẩm nang	Đội nội dung	Biên tập duyệt	Cập nhật định kỳ	Có
Hỏi đáp công khai	Member	Hậu kiểm bằng AI và moderator	Giữ mãi, gộp câu trùng	Có, sau khi ẩn danh
Bảng tin “Mây hôm nay”	Member tại chỗ, đội địa phương	AI kiểm ảnh và vị trí, moderator xem	Hết hạn sau 24 giờ, lưu vào lịch sử	Có, cho dự báo và gợi ý
Nhật ký chuyến đi	Member	Hậu kiểm	Giữ mãi nếu công khai	Có, nếu người đăng đồng ý
Review	Khách đã booking	Hàng chờ nếu bị báo cáo	Không xóa, chỉ ẩn khi vi phạm	Có
Kèo ghép đi chung	Member	AI gắn cờ, moderator xử lý	Đóng sau chuyến	Chỉ để ghép, không để huấn luyện
Ưu đãi và sự kiện	Đối tác, admin	Admin duyệt, gắn nhãn tài trợ	Có ngày hết hạn	Có

Phân loại chung cho mọi nội dung: khu vực (Đỉnh Gió, Thảo Nguyên, Khe Cải, Trung Tâm, Sống Lưng Khủng Long, Mống Vàng), loại hình, mùa, ngôn ngữ, mức công khai. Có sơ đồ thẻ chung thì tìm kiếm, lọc và AI đều dùng lại được.

7. Lộ trình build hợp nhất (18 sprint)

Khoảng 36 tuần nếu làm một mình, mỗi sprint 2 tuần. Có 2 đến 3 lập trình viên thì pha 2 và pha 3 chạy song song và rút còn khoảng 5 đến 6 tháng. Nếu cần ra mắt sớm, giữ pha 1 và pha 3 phần concierge, dời kèo ghép và nội dung cộng đồng sang sau.

Sprint	Mục tiêu	Kết quả cần có
Pha 1: Nền tảng giao dịch		

Sprint	Mục tiêu	Kết quả cần có
0. Nền móng	Repo, CLAUDE.md, Supabase staging và production, CI, schema nền	Deploy trang trống; migration chạy tự động
1. Tài khoản và phân quyền	Đăng ký, OTP, 3 nhóm người dùng	RLS chặn truy cập chéo; test phân quyền đạt
2. Hồ sơ nhà cung cấp và duyệt	Wizard đăng cơ sở, phiên bản, huy hiệu cấp 1 và 2	Hàng chờ duyệt có checklist; audit log
3. Lịch trống và giá	Lịch kéo thả, mẫu mùa, Zalo, iCal	Không đặt trùng; chủ cập nhật một tháng trong vài phút
4. Trang công khai	Danh sách, lọc theo ngày, bản đồ, SEO, dự báo mây	Lighthouse mobile tốt; chỉ hiện cơ sở đã duyệt
5. Booking và ví đối tác	Giữ chỗ, xác nhận một chạm, QR check-in, ví, ghi nhận phí 50.000đ	Webhook an toàn và idempotent; phí ghi nhận đúng
6. Lõi chat mức bằng chứng	conversations, members, messages, hash chuỗi, chat 1-1 gắn booking, thông báo	Không UPDATE hoặc DELETE được tin; xuất PDF; log truy cập
7. Review xác thực	Review từ booking hoàn tất, double-blind	Không review được nếu thiếu booking_id
Pha 2: Cộng đồng		
8. Chat cộng đồng	Kênh thông báo, kênh chủ đề, nhóm đối tác, phòng chuyến, vai trò moderator, báo cáo tin	Phòng chuyến tự tạo và tự đóng; test phân quyền theo bảng mục 3.4
9. Kèo ghép đi chung	Đăng kèo, xin ghép, duyệt, phòng chat của kèo, điểm tin cậy, SOS	Thông tin liên hệ chỉ hiện sau khi chấp nhận; có nút báo cáo
10. Nhà xe và dịch vụ khác	Tuyến, điểm đón, chuyến, ghế; xe máy, porter, tour, quán, cứu hộ	Khách chọn điểm đón dọc tuyến; không bán trùng ghế
11. Nội dung cộng đồng	Hỏi đáp, bảng tin mây, nhật ký, blog, sơ đồ thẻ chung	Mỗi loại nội dung đi qua cùng khung duyệt
Pha 3: Dữ liệu và AI		
12. Nền tảng dữ liệu	Đồng bộ sang chỉ mục vector và kho phân tích, che thông tin cá nhân, legal_holds, quy trình xuất	Quét mẫu embedding không còn SĐT hay CCCD; khôi phục sao lưu thử thành công
13. Concierge và tự nhận booking	Chatbot theo lịch thật, giữ chỗ 30 phút, xác nhận một chạm	Sai giá hoặc lịch bằng 0 trên bộ 200 câu chuẩn

Sprint	Mục tiêu	Kết quả cần có
14. Admin copilot và kiểm duyệt	Tóm tắt tranh chấp, tìm vụ tương tự, bot kiểm duyệt	Mọi lần AI đọc dữ liệu nhạy cảm có log; chống prompt injection qua 30 mẫu tấn công
15. Trợ lý đối tác và phân tích	Gợi ý giá, soạn trả lời, hỏi kho dữ liệu bằng ngôn ngữ tự nhiên	Chỉ đọc view đã duyệt; mỗi trợ lý có công tắc tắt
Pha 4: Hoàn thiện và mở		
16. Quyền lợi member và thống kê	Điểm Mây, cảnh báo mây và giá, thống kê cho đối tác, dashboard admin	Điểm chỉ cộng khi booking hoàn tất
17. Ra mắt	Bật phí khi đạt 10.000 member đã xác minh, kiểm thử bảo mật, pháp lý, beta 30 đến 50 nhà cung cấp	Báo cáo kiểm thử bảo mật; điều khoản được luật sư rà soát

8. Prompt mẫu cho các phần mới

Chat cộng đồng (Sprint 8):

> *Thực hiện Sprint 8 dựa trên lõi chat ở Sprint 6. Thêm các loại conversation: announcement, topic, partner_group, trip_room, với tier là social. Thêm bảng quyền theo vai trò member, moderator, owner, admin và kiểm tra bằng RLS. Phòng trip_room tự tạo theo ngày đến của booking đã xác nhận và tự đóng 3 ngày sau ngày đi. Thành viên sửa hoặc xóa tin của mình trong 15 phút nhưng bản gốc lưu trong message_versions. Thêm báo cáo tin và hàng chờ moderator. Viết test cho từng ô của bảng phân quyền.*

Kèo ghép đi chung (Sprint 9):

> *Thực hiện Sprint 9. Tạo bảng trips_share (loại: room, tour, photo; chưa làm ghép xe), join_requests, trust_profiles. Chỉ user đã xác minh SĐT mới đăng hoặc xin ghép. Khi người đăng duyệt một yêu cầu thì mở conversation kiểu share_room. Thông tin liên hệ cá nhân chỉ hiện sau khi hai bên chấp nhận. Thêm nút báo cáo, chia sẻ vị trí hành trình và nhắc điều khoản. Viết test cho việc lộ thông tin trước khi chấp nhận.*

Nền tảng dữ liệu và truy xuất AI (Sprint 12):

> *Thực hiện Sprint 12. Tạo pipeline lấy tin nhắn mới từ messages, che SĐT, CCCD, số tài khoản và địa chỉ bằng quy tắc cộng bộ phân loại, chia thành đoạn 20 tin, lưu embedding vào pgvector kèm conversation_id, tier và danh sách user được phép đọc. Hàm tìm kiếm phải lọc theo quyền của user đang hỏi ở tầng SQL, không nhận user_id từ client. Ghi access_logs cho mọi lần đọc mức bằng chứng. Viết test: user A không bao giờ nhận được đoạn thuộc phòng của user B, kể cả khi prompt yêu cầu.*

Admin copilot (Sprint 14):

> *Thực hiện Sprint 14. Công cụ summarize_thread nhận ticket_id, kiểm tra admin có quyền với ticket đó, đọc chuỗi tin theo seq, trả bản tóm tắt kèm trích dẫn message_id. Thêm find_similar_cases bằng vector trên các vụ đã đóng đã ẩn danh. Không có công cụ hoàn tiền hay đổi giá. Nội dung tin nhắn được đưa vào model dưới dạng dữ liệu có đánh dấu, và thêm test với 30 tin nhắn chứa chỉ dẫn độc hại.*

9. Tiêu chí nghiệm thu cho chat và dữ liệu

- ☐ User không đọc hoặc ghi được phòng mình không là thành viên (thử với 5 vai trò)
- ☐ Không UPDATE hoặc DELETE được tin mức bằng chứng, kể cả từ code ứng dụng
- ☐ Kiểm tra hash chuỗi phát hiện được khi sửa tay trong DB
- ☐ Bản xuất PDF có mã xác thực khớp với dữ liệu gốc
- ☐ Mọi lần admin xem chat mức bằng chứng đều có log kèm lý do
- ☐ Quét 1.000 đoạn embedding ngẫu nhiên không còn SĐT hay CCCD
- ☐ Chatbot khách không trả lời được nội dung chat của người khác sau 30 mẫu tấn công prompt injection
- ☐ Giá và lịch AI trả lời khớp DB 100% trên bộ 200 câu chuẩn
- ☐ Khôi phục sao lưu thử thành công
- ☐ Công tắc tắt khẩn cấp từng trợ lý AI hoạt động

10. Rủi ro và cách giảm

Rủi ro	Cách giảm
Chat xã hội thành nơi lách phí hoặc lừa đảo	AI lọc, nhãn đối tác, báo cáo; giữ lợi ích riêng cho booking trên web
Kèo ghép gây sự cố an toàn	Xác minh SĐT, hồ sơ tin cậy, SOS, điều khoản, hỏi luật sư trước khi mở ghép xe
Rò rỉ nội dung chat	RLS, mã hóa, log truy cập, kiểm thử thâm nhập
AI đọc nhầm dữ liệu	Quyền ở tầng DB, bộ test tấn công, công tắc tắt
Chi phí lưu trữ và AI tăng nhanh	Chuyển lưu trữ lạnh, dùng mô hình nhỏ cho việc đơn giản, lưu đệm câu trả lời lặp lại
Vi phạm quy định dữ liệu cá nhân	Luật sư, đồng ý rõ ràng, hồ sơ đánh giá tác động
Quá tải khi làm một mình	Chia pha, cắt phạm vi như mục 7, thuê ngoài thiết kế giao diện và kiểm thử bảo mật

11. Các điểm cần bạn chốt

1. Mở ghép xe (chia chi phí) ngay từ đầu, hay chỉ ghép phòng, tour, chụp ảnh? Đề xuất: ghép phòng, tour, chụp ảnh trước; ghép xe sau khi hỏi luật sư.

2. Thời gian lưu chat: 3 năm cho mức bằng chứng và 12 tháng cho mức xã hội có phù hợp không?
3. Cho AI trả lời thay chủ cơ sở trong chat 1-1 ngay từ đầu không? Đề xuất: có tùy chọn, mặc định tắt.
4. Dùng Supabase Realtime hay dịch vụ chat chuyên dụng (Stream, Sendbird)? Đề xuất: Supabase đến khi vượt giới hạn.
5. Có thông báo cho người dùng khi admin xem chat của họ không?
6. Pháp nhân vận hành và tên miền đã sẵn sàng chưa (cần cho cổng thanh toán và Zalo OA doanh nghiệp)?